Relatório Técnico — Avaliação de Segurança do NexaSense

Projeto: Do Protótipo ao Produto Seguro: Avaliação de Segurança de um Dispositivo IoT

Organização fictícia: NexaHome Technologies

Dispositivo: NexaSense

Plataforma: ESP32

Ambiente de desenvolvimento: Wokwi

Linguagem: C++ (Arduino)

1. Introdução

Este relatório apresenta uma avaliação inicial de segurança do dispositivo IoT NexaSense, desenvolvido no cenário proposto pela NexaHome Technologies.

O dispositivo tem como finalidade monitorar condições ambientais, coletando informações de temperatura e umidade por meio de sensores e utilizando um microcontrolador ESP32.

O objetivo da atividade é compreender a arquitetura do dispositivo, identificar superfícies de ataque, analisar o firmware, observar possíveis exposições de informações e propor medidas de proteção para uma futura versão comercial.

Devido à ausência de uma placa física, a avaliação prática foi desenvolvida utilizando o simulador Wokwi.

2. Descrição do dispositivo

O protótipo desenvolvido utiliza os seguintes componentes:

Componente	Descrição
ESP32	Microcontrolador responsável pelo processamento
DHT22	Sensor de temperatura e umidade
GPIO15	Pino utilizado para receber os dados do sensor
Interface serial	Exibição de mensagens e leituras
Wokwi	Ambiente de simulação

O firmware foi desenvolvido em C++ utilizando a plataforma Arduino.

3. Arquitetura do sistema

O funcionamento do protótipo ocorre da seguinte maneira:

1. O ESP32 é inicializado.
2. O firmware configura o sensor DHT22.
3. O sensor realiza as medições ambientais.
4. Os dados são enviados ao ESP32 pelo GPIO15.

5. O firmware processa os valores recebidos.
6. As informações são exibidas pelo Serial Monitor.

A arquitetura atual não possui conectividade Wi-Fi, servidor externo ou protocolo MQTT/HTTP implementado.

4. Metodologia utilizada

A avaliação foi organizada em etapas:

- Montagem e validação do protótipo.
- Registro da arquitetura.
- Inspeção inicial do código-fonte.
- Identificação das interfaces e superfícies de ataque.
- Cálculo do hash SHA-256 do código-fonte.
- Demonstração controlada da exposição de informações pela interface serial.
- Avaliação preliminar de riscos.
- Elaboração de recomendações de segurança.

As atividades foram realizadas em ambiente simulado, sem testes contra dispositivos de terceiros ou serviços externos.

5. Análise do firmware

O firmware realiza a inicialização do ESP32, configura o sensor DHT22 e apresenta os valores de temperatura e umidade por meio da comunicação serial.

Durante a inspeção do código, foram identificados os seguintes aspectos:

- Comunicação serial configurada em 115200 baud.
- Mensagens de inicialização e depuração.
- Exibição dos dados coletados pelo sensor.
- Verificação de falhas nas leituras por meio de `isnan()`.
- Ausência de implementação de autenticação.
- Ausência de implementação de criptografia.
- Ausência de conexão Wi-Fi.
- Ausência de mecanismo de atualização OTA.

Esses itens representam características do firmware atual. A ausência de funcionalidades de segurança no protótipo não comprova, isoladamente, uma vulnerabilidade explorável.

6. Preservação e integridade do firmware

Foi preservada uma cópia do código-fonte utilizado na simulação.

Arquivo: `sketch.ino`

Algoritmo: SHA-256

Ferramenta: Windows PowerShell

Hash registrado:

`6C68D4367912602465605A3D059DCC698083DAA7EA5DA94021A83ABF3EDED64B`

O hash foi calculado sobre o arquivo de código-fonte `.ino`, e não sobre uma imagem binária compilada do firmware.

O valor foi registrado em `firmware/hashes.txt` para permitir a verificação de futuras alterações no código analisado.

7. Análise das interfaces físicas

Durante a montagem simulada, foram identificadas as seguintes conexões:

- GPIO15: comunicação com o sensor DHT22.
- 3V3: alimentação do sensor.
- GND: aterramento.
- Interface serial: saída de informações de depuração.

As interfaces UART e JTAG não foram examinadas fisicamente, pois não foi utilizada uma placa ESP32 real.

A memória flash também não foi extraída ou inspecionada.

Esses itens permanecem como atividades não realizadas e devem ser avaliados em uma futura análise com hardware físico.

8. Análise das comunicações

A comunicação efetivamente observada no protótipo foi a comunicação serial entre o ESP32 e o Serial Monitor do Wokwi.

Não foram implementados ou testados:

- Wi-Fi;
- MQTT;
- HTTP ou HTTPS;
- TCP ou UDP em nível de aplicação;
- Comunicação com servidores externos.

Por esse motivo, não foi possível avaliar a autenticação, confidencialidade e integridade de tráfego de rede.

Não foram realizadas capturas de pacotes com Wireshark, pois o firmware atual não gera tráfego de rede do dispositivo.

9. Demonstração controlada e achado identificado

F01 — Exposição de informações pela interface serial

Descrição: o firmware apresenta informações de inicialização, temperatura, umidade e mensagens de depuração por meio da interface serial.

Evidência: captura do Serial Monitor durante a execução da simulação Wokwi.

Condição observada: os dados podem ser visualizados diretamente pelo monitor serial.

Impacto potencial: em um dispositivo físico, caso a interface esteja acessível, uma pessoa com acesso físico poderia observar as informações transmitidas.

Limitação: não foi demonstrado acesso não autorizado a uma placa física nem exploração remota.

10. Avaliação de riscos

A classificação abaixo é preliminar e considera o cenário simulado.

Achado	Evidência	Impacto	Probabilidade	Prioridade	Recomendação
F01 — Exposição serial	Serial Monitor	Baixo a moderado	Baixa	Baixa	Restringir acesso físico e reduzir mensagens de depuração

Os demais pontos identificados durante o mapeamento são itens para investigação futura, não vulnerabilidades confirmadas.

11. Referências de segurança

A avaliação considera os seguintes referenciais indicados no enunciado:

- **OWASP IoT Security Testing Guide:** metodologia para organizar testes e identificar superfícies de ataque.
- **NIST IR 8259A:** capacidades básicas de segurança esperadas em dispositivos IoT.
- **ETSI EN 303 645:** recomendações para proteção de produtos IoT de consumo.
- **MITRE EMB3D:** modelo de ameaças para dispositivos embarcados.
- **Espressif ESP-IDF Security Documentation:** documentação dos mecanismos de proteção disponíveis para ESP32.

Essas referências fundamentam a metodologia e as recomendações de proteção propostas.

12. Recomendações e plano de hardening

Para uma futura versão comercial do NexaSense, recomenda-se:

1. Reduzir mensagens de depuração na versão de produção.
2. Restringir o acesso físico às interfaces de depuração.
3. Avaliar os mecanismos de proteção de UART e JTAG.
4. Implementar Secure Boot.
5. Avaliar a utilização de Flash Encryption.
6. Proteger credenciais e parâmetros sensíveis.
7. Utilizar comunicação protegida caso o Wi-Fi seja implementado.
8. Implementar atualizações autenticadas e verificar a integridade do firmware.
9. Manter controle de versões e registros de integridade.

As medidas propostas ainda não foram implementadas no protótipo.

13. Limitações da avaliação

A avaliação foi realizada exclusivamente por meio de simulação no Wokwi e inspeção do código-fonte.

Não foram realizados:

- Testes em placa ESP32 física.
- Inspeção física de UART e JTAG.
- Extração ou análise da memória flash.
- Captura de tráfego de rede do dispositivo.
- Testes de Wi-Fi, MQTT ou HTTP.
- Testes de atualização de firmware.
- Demonstração de exploração remota.

Essas limitações devem ser consideradas na interpretação dos resultados.

14. Estudo de caso real — Vulnerabilidade nas câmeras TRENDnet SecurView

14.1 Dispositivo analisado

O caso envolve câmeras IP da linha SecurView, comercializadas pela empresa TRENDnet para monitoramento remoto de residências e estabelecimentos.

14.2 Superfície de ataque

A superfície de ataque envolvia a interface de comunicação pela internet e o software responsável pelo controle de acesso às transmissões de áudio e vídeo.

14.3 Problema identificado

Em 2012, foi identificada uma falha que permitia acessar transmissões das câmeras sem informar as credenciais de autenticação.

Além disso, a FTC apontou que credenciais de usuários eram transmitidas em texto legível pela internet e armazenadas dessa forma nos dispositivos móveis utilizados com as câmeras.

O problema resultou na exposição pública de transmissões privadas de centenas de consumidores.

14.4 Medidas de mitigação

Entre as medidas adotadas estavam a disponibilização de atualizações de firmware, a comunicação aos consumidores afetados e a exigência de um programa abrangente de segurança da informação.

14.5 Relação com o NexaSense

O caso demonstra a importância de proteger informações transmitidas por dispositivos IoT, implementar autenticação adequada e realizar testes de segurança no software.

No NexaSense, essas lições fundamentam as recomendações de proteção da interface serial, segurança das futuras comunicações Wi-Fi e controle de acesso.

É importante destacar que o problema das câmeras TRENDnet não foi reproduzido no NexaSense. O caso foi utilizado como referência externa para fundamentar as recomendações de segurança.

14.6 Fonte

Federal Trade Commission (FTC). Marketer of Internet-Connected Home Security Video Cameras Settles FTC Charges It Failed to Protect Consumers' Privacy. 2013.

Disponível em: https://www.ftc.gov/news-events/news/press-releases/2013/09/marketer-internet-connected-home-security-video-cameras-settles-ftc-charges-it-failed-protect

Acesso em: 3 nov. 2026.

15. Conclusão

A atividade permitiu desenvolver um protótipo funcional com ESP32 e DHT22, registrar o firmware e seu hash SHA-256, documentar a arquitetura e identificar pontos de atenção relacionados à interface serial.

A demonstração controlada evidenciou que informações ambientais e mensagens de depuração são exibidas pela interface serial.

A avaliação também identificou limitações decorrentes da utilização de um ambiente simulado, especialmente em relação à análise física das interfaces, memória e comunicação de rede.

Como resultado, foi elaborado um conjunto de recomendações de segurança para orientar uma futura versão comercial do NexaSense.

A realização de testes adicionais em hardware físico será necessária para ampliar a cobertura e confirmar os pontos ainda não verificados.